

Лабораторная работа №8

Изучение сеансов связи по протоколам Telnet и SSH с помощью анализатора Wireshark

Цель работы

Целью данной лабораторной работы является изучение особенностей передачи данных в рамках сеансов удалённого администрирования сетевых устройств по протоколам Telnet и SSH, а также практическое освоение методики перехвата и анализа соответствующего трафика средствами анализатора Wireshark с применением функции реконструкции содержимого сеанса связи TCP (Follow TCP Stream).

Задачи работы

В ходе выполнения работы решались следующие задачи: подготовка рабочей среды на базе виртуальной топологии EVE-NG с настройкой маршрутизатора Cisco для удалённого доступа по протоколам Telnet и SSH; перехват сетевого трафика на узле Kali Linux средствами анализатора Wireshark во время установления сеанса связи с маршрутизатором по протоколу Telnet и реконструкция содержимого сеанса; повторный перехват трафика во время аналогичного сеанса связи по протоколу SSH; сопоставительный анализ возможностей получения чувствительных данных пользователя из перехваченного трафика по защищённому и незащищённому протоколу.

Ход работы

Подготовка рабочей среды

В среде эмуляции EVE-NG была развёрнута сетевая топология, включающая узел А под управлением операционной системы Kali Linux и маршрутизатор R1 (образ Cisco IOL), подключённые непосредственно посредством сегмента Ethernet. Узел А подключён к маршрутизатору через

интерфейс eth0, маршрутизатор — через интерфейс Ethernet0/1. Топология лабораторной работы представлена на рис. 1.

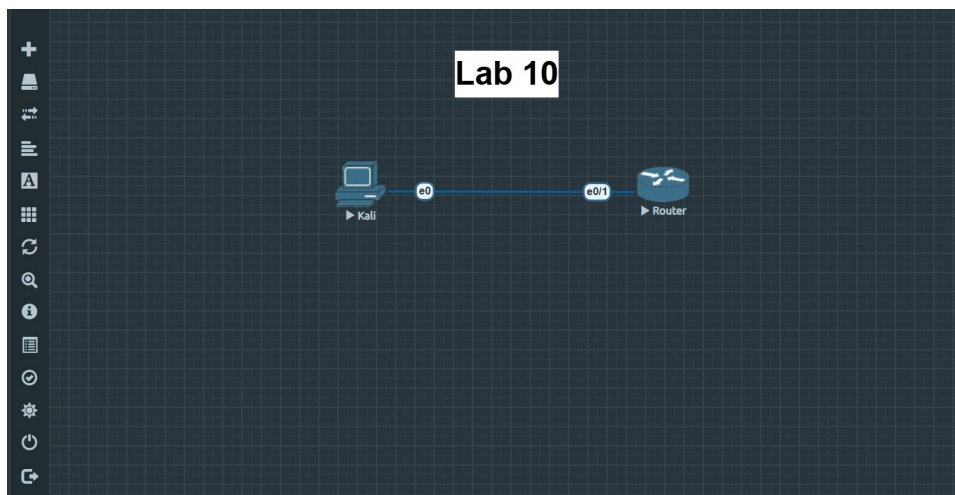
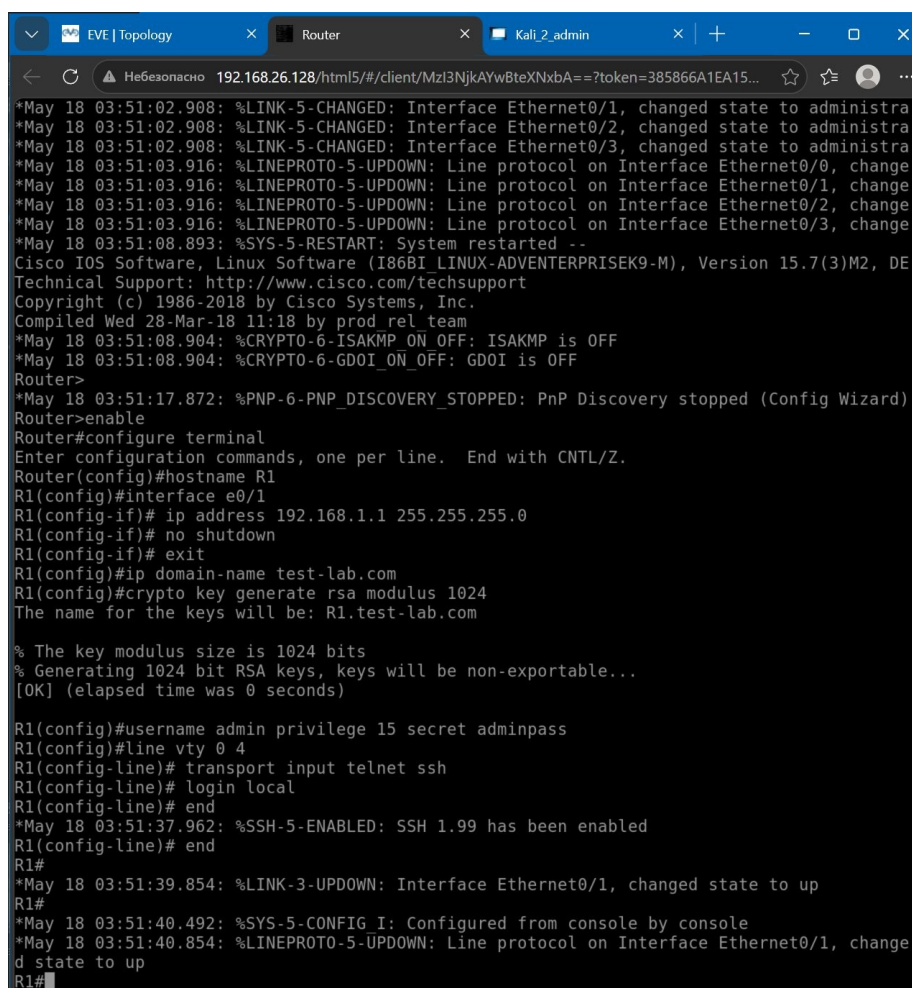


Рис. 1. Сетевая топология для изучения сеансов связи по протоколам Telnet и SSH

На маршрутизаторе R1 была установлена консоль управления, командой *enable* выполнен переход в привилегированный режим, командой *configure terminal* — в режим глобальной конфигурации. Имя устройства было изменено на R1, на интерфейсе Ethernet0/1 командой *ip address 192.168.1.1 255.255.255.0* был назначен IP-адрес 192.168.1.1/24, после чего интерфейс был переведён в активное состояние командой *no shutdown*.

Для последующей настройки удалённого доступа по протоколу SSH было задано доменное имя маршрутизатора командой *ip domain-name test-lab.com* и сгенерирована пара криптографических ключей RSA с длиной модуля 1024 бит командой *crypto key generate rsa modulus 1024*. В локальной базе учётных записей маршрутизатора создан пользователь admin с уровнем привилегий 15 и паролем adminpass командой *username admin privilege 15 secret adminpass*. В режиме конфигурации линий виртуального терминала vty 0 4 командой *transport input telnet ssh* был разрешён входящий доступ по обоим протоколам, командой *login local* активирована аутентификация по локальной базе учётных записей. По окончании настройки сервис SSH был

запущен автоматически, что подтверждено сообщением %SSH-5-ENABLED: SSH 1.99 has been enabled в выводе консоли маршрутизатора (рис. 2).



```
*May 18 03:51:02.908: %LINK-5-CHANGED: Interface Ethernet0/1, changed state to administra
*May 18 03:51:02.908: %LINK-5-CHANGED: Interface Ethernet0/2, changed state to administra
*May 18 03:51:02.908: %LINK-5-CHANGED: Interface Ethernet0/3, changed state to administra
*May 18 03:51:03.916: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/0, change
*May 18 03:51:03.916: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/1, change
*May 18 03:51:03.916: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/2, change
*May 18 03:51:03.916: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/3, change
*May 18 03:51:08.893: %SYS-5-RESTART: System restarted --
Cisco IOS Software, Linux Software (I86BI_LINUX-ADVENTERPRISEK9-M), Version 15.7(3)M2, DE
Technical Support: http://www.cisco.com/techsupport
Copyright (c) 1986-2018 by Cisco Systems, Inc.
Compiled Wed 28-Mar-18 11:18 by prod_rel_team
*May 18 03:51:08.904: %CRYPTO-6-ISAKMP ON OFF: ISAKMP is OFF
*May 18 03:51:08.904: %CRYPTO-6-GDOI_ON_OFF: GDOI is OFF
Router>
*May 18 03:51:17.872: %PNP-6-PNP_DISCOVERY_STOPPED: PnP Discovery stopped (Config Wizard)
Router>enable
Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#hostname R1
R1(config)#interface e0/1
R1(config-if)# ip address 192.168.1.1 255.255.255.0
R1(config-if)# no shutdown
R1(config-if)# exit
R1(config)#ip domain-name test-lab.com
R1(config)#crypto key generate rsa modulus 1024
The name for the keys will be: R1.test-lab.com

% The key modulus size is 1024 bits
% Generating 1024 bit RSA keys, keys will be non-exportable...
[OK] (elapsed time was 0 seconds)

R1(config)#username admin privilege 15 secret adminpass
R1(config)#line vty 0 4
R1(config-line)# transport input telnet ssh
R1(config-line)# login local
R1(config-line)# end
*May 18 03:51:37.962: %SSH-5-ENABLED: SSH 1.99 has been enabled
R1(config-line)# end
R1#
*May 18 03:51:39.854: %LINK-3-UPDOWN: Interface Ethernet0/1, changed state to up
R1#
*May 18 03:51:40.492: %SYS-5-CONFIG I: Configured from console by console
*May 18 03:51:40.854: %LINEPROTO-5-UPDOWN: Line protocol on Interface Ethernet0/1, change
d state to up
R1#
```

Рис. 2. Настройка маршрутизатора R1 для удалённого доступа по протоколам Telnet и SSH

На узле А интерфейсу eth0 командой *ifconfig eth0 192.168.1.2/24 up* был назначен статический IP-адрес 192.168.1.2/24. Корректность сетевого подключения между узлом А и маршрутизатором R1 подтверждена успешным прохождением ICMP-пакетов командой *ping 192.168.1.1*.

Изучение сеанса Telnet с помощью программы Wireshark

На узле А был запущен анализатор Wireshark, в качестве интерфейса захвата выбран eth0, начат перехват сетевого трафика. В отдельном окне терминала командой *telnet 192.168.1.1* было инициировано подключение к

маршрутизатору R1 по протоколу Telnet, использующему по умолчанию TCP-порт 23. На запрос Username введено имя пользователя admin, на запрос Password — пароль adminpass. После успешной аутентификации в режиме привилегированного доступа маршрутизатора командой *show running-config* была отображена текущая конфигурация маршрутизатора. После завершения сеанса перехват трафика в анализаторе Wireshark был остановлен.

В поле фильтра отображения анализатора Wireshark было введено значение *telnet*, в результате чего в списке пакетов отображены исключительно сообщения протокола Telnet. На любом из пакетов сеанса по правой кнопке мыши был вызван контекстный пункт меню Follow → TCP Stream, отображающий реконструированное содержимое TCP-сеанса. В появившемся окне Follow TCP Stream отображено полное содержимое сеанса связи в виде открытого текста (рис. 3).

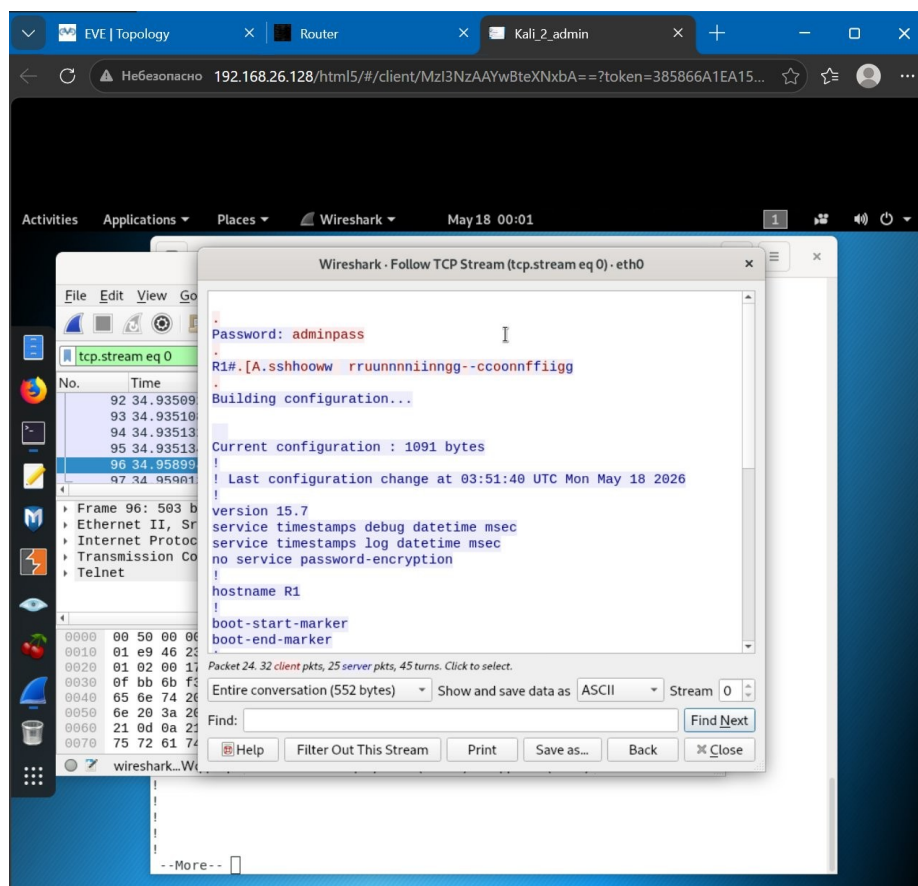


Рис. 3. Реконструкция сеанса Telnet в окне Follow TCP Stream анализатора Wireshark

В реконструированном содержимом сеанса в открытом виде отображён пароль пользователя в строке *Password: adminpass*, а также текст команды *show running-config* с эффектом удвоения символов (*ssshhhhoowwwrrruuunnnnniiinnnggg-ccsooonnnfffiigg*). Удвоение символов связано с особенностью работы протокола Telnet в режиме отображения «эхо»: каждый символ, набранный пользователем на клавиатуре, передаётся клиентом на сервер и одновременно возвращается сервером обратно клиенту для вывода на экран, что приводит к одновременному отображению в реконструкции как клиентских, так и серверных байт. Также в открытом виде доступен весь вывод команды *show running-config*, включающий содержимое конфигурационного файла маршрутизатора (показанные на скриншоте строки *version 15.7*, *hostname R1*, *service timestamps*, *boot-start-marker*, *boot-end-marker* и далее по объёму 1091 байт).

Имя пользователя в реконструированном содержимом отображено отдельной серией повторяющихся символов *admin*, не показанной на представленной части окна, но присутствующей в полном содержимом сеанса по тому же принципу удвоения символов протоколом Telnet. Указанное содержимое сеанса связи доступно для непосредственного прочтения произвольным наблюдателем, имеющим возможность перехвата трафика на любом участке маршрута следования сетевых пакетов между узлом А и маршрутизатором R1.

Изучение сеанса SSH с помощью программы Wireshark

В анализаторе Wireshark был повторно запущен перехват сетевого трафика на интерфейсе *eth0*. В окне терминала командой *ssh -l admin 192.168.1.1* инициировано подключение к маршрутизатору R1 по протоколу SSH, использующему по умолчанию TCP-порт 22. Поскольку соединение к

указанному узлу устанавливалось впервые, клиент SSH отобразил оповещение безопасности с указанием отпечатка ключа сервера (RSA key fingerprint SHA256) и запросом на подтверждение продолжения подключения. Подтверждение продолжения подключения предоставлено вводом yes, отпечаток ключа маршрутизатора добавлен в список доверенных узлов файла known_hosts. На запрос Password введён пароль adminpass, аутентификация прошла успешно, командой show running-config на маршрутизаторе отображена текущая конфигурация. После завершения сеанса перехват трафика остановлен.

В поле фильтра отображения анализатора Wireshark было введено значение ssh, функцией Follow TCP Stream была выполнена реконструкция содержимого TCP-сеанса (рис. 4).

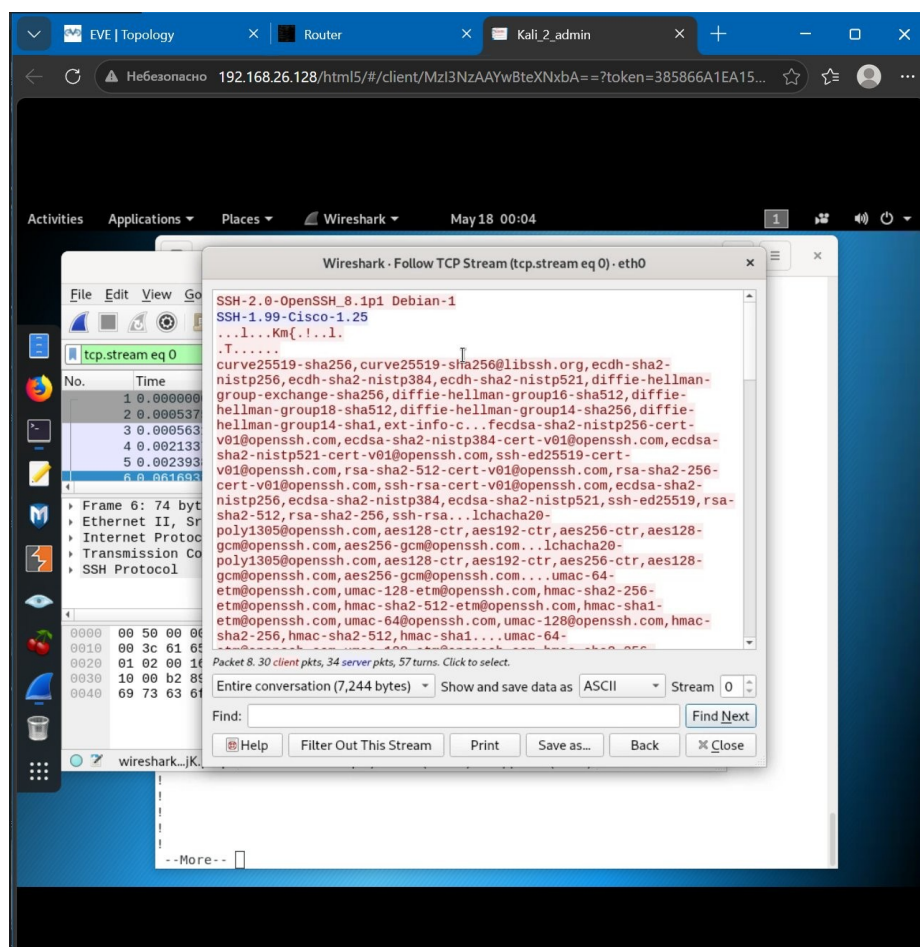


Рис. 4. Реконструкция сеанса SSH в окне Follow TCP Stream анализатора Wireshark

В реконструированном содержимом сеанса в открытом виде доступны исключительно начальные сообщения этапа согласования параметров шифрования протокола SSH: идентификационные строки клиента (SSH-2.0-OpenSSH_8.1p1 Debian-1) и сервера (SSH-1.99-Cisco-1.25), позволяющие сторонам определить совместимые версии протокола, а также сообщения SSH_MSG_KEXINIT с перечнями поддерживаемых каждой стороной криптографических алгоритмов: алгоритмов согласования общего секретного ключа (curve25519-sha256, ecdh-sha2-nistp256, diffie-hellman-group-exchange-sha256, diffie-hellman-group14-sha256 и другие), алгоритмов аутентификации сервера по открытому ключу (ssh-ed25519, rsa-sha2-512, rsa-sha2-256, ssh-rsa и другие), алгоритмов симметричного шифрования (chacha20-poly1305, aes256-ctr, aes192-ctr, aes128-ctr и другие), а также алгоритмов проверки целостности сообщений (hmac-sha2-256, hmac-sha2-512, hmac-sha1, umac-128 и другие).

Все последующие сообщения сеанса, включая данные аутентификации пользователя (имя пользователя admin и пароль adminpass), команды пользователя (show running-config), а также вывод указанной команды с полной конфигурацией маршрутизатора, оказываются инкапсулированы в защищённый туннель SSH и недоступны для непосредственного прочтения средствами анализатора Wireshark. Произвольный наблюдатель, перехватывающий трафик между узлом А и маршрутизатором R1, может определить факт установления соединения по протоколу SSH, версии клиентского и серверного программного обеспечения, а также перечни согласованных криптографических алгоритмов, однако не имеет возможности получить чувствительные данные пользователя в отсутствие закрытых ключей сессии.

Вывод

В ходе выполнения лабораторной работы был перехвачен и проанализирован сетевой трафик, формируемый при установлении сеансов удалённого администрирования маршрутизатора Cisco по протоколам Telnet и SSH. Маршрутизатор R1 был сконфигурирован для удалённого доступа по обоим протоколам с аутентификацией по локальной базе учётных записей; на маршрутизаторе создан пользователь admin с паролем adminpass и уровнем привилегий 15, а также сгенерирована пара криптографических ключей RSA, необходимая для функционирования сервиса SSH.

Экспериментально подтверждена незащищённость протокола Telnet применительно к передаче чувствительных данных пользователя. В перехваченном трафике сеанса Telnet средствами функции Follow TCP Stream анализатора Wireshark получено полное содержимое сеанса связи в открытом виде, включая пароль пользователя (adminpass), вводимые пользователем команды и весь вывод этих команд, в том числе содержимое конфигурационного файла маршрутизатора, полученное по команде show running-config. Указанные данные доступны для непосредственного прочтения без необходимости какой-либо дополнительной обработки.

Также экспериментально подтверждена эффективность защиты, обеспечиваемой протоколом SSH. В перехваченном трафике сеанса SSH средствами функции Follow TCP Stream получены исключительно начальные сообщения этапа согласования параметров шифрования: идентификационные строки клиента и сервера, а также перечни поддерживаемых криптографических алгоритмов. Все последующие сообщения сеанса, включая данные аутентификации пользователя и команды администрирования, оказались инкапсулированы в защищённый туннель и недоступны для прочтения средствами анализатора.

Сопоставительный анализ двух перехваченных сеансов подтверждает обоснованность повсеместного использования протокола SSH в современных сетях передачи данных применительно к задачам удалённого администрирования сетевого оборудования. Протокол Telnet, не предусматривающий механизмов защиты передаваемых данных, в настоящее время может применяться исключительно в контролируемых лабораторных условиях либо для доступа к устаревшему оборудованию, не поддерживающему протокол SSH, при условии гарантированной изоляции сегмента сети, в котором осуществляется передача трафика.

Контрольные вопросы

1. Для чего используются анализаторы сетевого трафика?

Анализаторы сетевого трафика представляют собой программные или программно-аппаратные средства, предназначенные для перехвата, декодирования и последующего анализа сетевых пакетов, передаваемых через указанный сегмент сети. Анализаторы используются для широкого круга задач: при проектировании, развёртывании и отладке сетевой инфраструктуры — для проверки корректности работы сетевых протоколов и выявления причин возникающих неполадок; при администрировании сетей — для мониторинга загрузки каналов связи, выявления аномальных потоков трафика и узлов с нештатным поведением; при обеспечении информационной безопасности — для выявления попыток сетевых атак, утечек данных, наличия вредоносного программного обеспечения в сегменте сети; при проведении расследований инцидентов информационной безопасности — для реконструкции последовательности действий нарушителя по сохранённым копиям перехваченного трафика; при изучении сетевых протоколов в учебных и исследовательских целях. Анализаторы также активно применяются нарушителями в составе сетевых атак — для перехвата чувствительных данных, передаваемых по незащищённым каналам

связи, проведения разведки сетевой инфраструктуры и подготовки последующих этапов атаки. Наиболее распространённым анализатором сетевого трафика общего назначения является Wireshark, использовавшийся в настоящей лабораторной работе.

2. Какие сетевые протоколы не поддерживают криптографические преобразования для защиты передаваемых данных?

К сетевым протоколам, исторически не поддерживающим криптографические преобразования для защиты передаваемых данных, относятся: Telnet — протокол удалённого доступа к командному интерпретатору сетевого устройства; HTTP (HyperText Transfer Protocol) — протокол передачи гипертекста, лежащий в основе сети Интернет; FTP (File Transfer Protocol) — протокол передачи файлов; POP3 (Post Office Protocol версии 3) и IMAP (Internet Message Access Protocol) в исходных версиях — протоколы получения электронной почты с сервера; SMTP (Simple Mail Transfer Protocol) в исходной версии — протокол передачи электронной почты между серверами; SNMPv1 и SNMPv2c (Simple Network Management Protocol версий 1 и 2c) — протоколы управления сетевыми устройствами; DNS (Domain Name System) в исходной версии — протокол разрешения доменных имён; NTP (Network Time Protocol) — протокол синхронизации времени. Для перечисленных протоколов в современных условиях разработаны защищённые альтернативы, инкапсулирующие исходные сообщения в TLS-туннель (HTTPS, FTPS, POP3S, IMAPS, SMTPS), либо использующие иные механизмы криптографической защиты (SSH вместо Telnet, SFTP и SCP поверх SSH вместо FTP, SNMPv3 с шифрованием и аутентификацией, DNSSEC и DNS over HTTPS/TLS, NTS для NTP).

3. Какие преимущества имеет взаимодействие по протоколу HTTPS по сравнению с протоколом HTTP?

Взаимодействие по протоколу HTTPS (HyperText Transfer Protocol Secure) по сравнению с протоколом HTTP имеет три ключевых преимущества, обеспечиваемых посредством инкапсуляции HTTP-сообщений в TLS-туннель. Во-первых, HTTPS обеспечивает конфиденциальность передаваемых данных: содержимое всех HTTP-сообщений (URL-адреса запрашиваемых ресурсов с параметрами, заголовки запросов, тела запросов и ответов, в том числе чувствительные данные пользователя — учётные данные, токены сессий, платёжные данные, персональные данные) шифруется с использованием симметричного алгоритма шифрования, согласованного сторонами на этапе установления TLS-соединения, и не может быть прочитано произвольным наблюдателем в проводящем сегменте сети. Во-вторых, HTTPS обеспечивает целостность передаваемых данных: к каждому переданному пакету прикладного уровня добавляется криптографический код аутентификации сообщений (HMAC) или вычисляется в составе режима шифрования с аутентификацией данных (AEAD), что позволяет принимающей стороне обнаружить любые модификации содержимого сообщений со стороны промежуточных узлов и отвергнуть искажённые сообщения. В-третьих, HTTPS обеспечивает аутентификацию веб-сервера посредством предъявления клиенту цифрового сертификата X.509, подписанного доверенным удостоверяющим центром: клиент проверяет принадлежность сертификата запрашиваемому доменному имени, действительность срока действия сертификата и наличие цепочки доверия до одного из удостоверяющих центров, корневой сертификат которого предустановлен в операционной системе или веб-обозревателе клиента. При успешной проверке клиент получает гарантию, что соединение установлено именно с владельцем указанного доменного имени, а не с произвольным узлом, контролируемым нарушителем.

4. Можно ли считать взаимодействие по протоколу HTTPS безопасным, если сертификат веб-сайта не является доверенным?

Взаимодействие по протоколу HTTPS с веб-сайтом, сертификат которого не является доверенным с точки зрения клиента, не может быть признано безопасным в общем случае. Недоверенный сертификат может свидетельствовать о нескольких различных по характеру ситуациях, среди которых: использование самоподписанного сертификата (часто применяется во внутренних и тестовых средах); использование сертификата, подписанного удостоверяющим центром, корневой сертификат которого не предустановлен в системе клиента (например, ведомственным удостоверяющим центром); истечение срока действия сертификата; отзыв сертификата удостоверяющим центром; несоответствие доменного имени сертификата запрашиваемому доменному имени; намеренное предъявление поддельного сертификата нарушителем, осуществляющим атаку «человек посередине» (MitM) с целью перехвата и модификации содержимого сеанса связи. Поскольку клиент в общем случае не может с уверенностью установить причину недоверия к сертификату, должна применяться презумпция наличия атаки, и взаимодействие должно быть прекращено. Шифрование канала и контроль целостности данных при недоверенном сертификате формально продолжают функционировать, однако в условиях возможной атаки «человек посередине» нарушитель получает доступ к ключам сессии, согласованным с подменённым сервером, и, как следствие, имеет возможность чтения и модификации передаваемого содержимого сеанса связи. Следовательно, факт использования протокола HTTPS сам по себе не обеспечивает безопасность взаимодействия — обязательным условием является успешная проверка цепочки доверия сертификата веб-сервера.

5. Какой номер порта используется сервером HTTPS по умолчанию?

Сервером HTTPS по умолчанию используется TCP-порт с номером 443, закреплённый за указанным протоколом организацией IANA (Internet Assigned Numbers Authority). При указании в URL-адресе схемы https:// без явного указания номера порта веб-обозреватель клиента инициирует TCP-соединение на порт 443 целевого узла. Для сравнения, протокол HTTP без шифрования по умолчанию использует TCP-порт 80, протокол Telnet — TCP-порт 23 (рассмотрен в настоящей лабораторной работе), протокол SSH — TCP-порт 22 (также рассмотрен в настоящей лабораторной работе).